Sprint chapter	Sheet	Task where this sheet is filled out
I. Developing threat models	Key Assets	4.1.2 Identifying key assets (Key Assets)
	Threat Actors	4.1.4 Profiling threat actors (Threat Actors)
II. Conduct gap analysis	Attack Surface	4.2.1 Mapping an attack surface (Attack Surface)
	Risks	4.2.2 Evaluating risks (Risks)
	Attack Vectors	4.2.4 Identifying attack vectors (Attack Vectors)
	Attack Scenarios	4.2.5 Envisioning attack scenarios (Attack Scenarios)
III. Choosing solutions	Solutions	4.3.2 Assessing detection solutions: continuous monitoring (Data sources)
		4.3.5 Assessing preventive solutions (Mitigations)
		4.3.8 Assessing detection solutions: honeypots (Honeypots)
IV. Creating a formal roadmap	Goals	4.4.2 Setting milestones for each solution (Goals)
	Stakeholders	4.4.3 Crafting arguments for each stakeholder (Stakeholders)

Use the info provided about the org to identify key assets included in scope of threat model 4.1.2 👑 **Key Assets**	Add notes about this asset. 4.1.2 Notes
Intellectual property (IP)	proprietary game source code
Payment information (PCI)	billing (paid subscriptions)
In-game private chat system	features end-to-end encryption
personally identifiable information (PII)	employee and customer information

Use the info provided about the org to identify key assets included in scope of threat model 4.1.2 👑 **Key Assets**	Add notes about this asset. 4.1.2 Notes

Use the info provided about the org to identify key assets included in scope of threat model 4.1.2 👑 **Key Assets**	Add notes about this asset. 4.1.2 Notes

Use the info provided about the org to identify key assets included in scope of threat model 4.1.2 👑 **Key Assets**	Add notes about this asset. 4.1.2 Notes

Use the info provided about the org to identify key assets included in scope of threat model 4.1.2 👑 **Key Assets**	Add notes about this asset. 4.1.2 Notes

Use the info provided about the org to identify key assets included in scope of threat model 4.1.2 👑 **Key Assets**	Add notes about this asset. 4.1.2 Notes

Use the info provided about the org to identify key assets included in scope of threat model 4.1.2 👑 **Key Assets**	Add notes about this asset. 4.1.2 Notes

Use the info provided about the org to identify key assets included in scope of threat model 4.1.2 👑 **Key Assets**	Add notes about this asset. 4.1.2 Notes

Complete the 👑 **Key Assets sheet** first to pre-populate this column's dropdown!		*Why* might this TA be motivated to access this asset?	*How* might we expect this TA to attack this asset?
4.1.2 👑 Key Assets	4.1.4 🥷 **Threat Actors**	4.1.4 Motivations ("why")	4.1.4 Typical attacks ("how")
Intellectual property (IP)	Cybercriminals	Selling stolen data, extortion	Phishing emails or malware infections installing ransomware
Intellectual property (IP)	Nation State Actors	Gaining technological advancements	Sophisticated data exfiltration or Lateral movement within networks,access to Internal development server
Intellectual property (IP)	Advanced Persiste…	Sabotage, undetected foothold	Sophisticated data exfiltration or Lateral movement within networks, access to Internal development server
Intellectual property (IP)	Insider Threats	revenge, Financial incentives from competitors, leverage	downloading on personal device, sharing login credentials, deleting or sabotaging
Payment information	Cybercriminals	theft, fraud, Monetizing stolen payment details or credentials	credit card skimming , fake logins, phishing, malware
Payment information	Advanced Persiste…	credential harvesting	spear phishing, zero day exploits, fileless malware
Payment information	Insider Threats	personal gain, retribution	misuse of credentials,
In-game private chat system	Cybercriminals	extortion, stay undetected to exploit any relevant data	malware infections exploit vulnerabilities, employ social engineering
In-game private chat system	Advanced Persiste…	long term access to personal material	custom malware, supply chain attacks, zero day exploits
In-game private chat system	Nation State Actors	protesting, promoting ideals, manipulating, revenge	DDoS attacks, hijacking accounts
In-game private chat system	Script Kiddies	fun, self promotion, revenge, curiosity	DDoS , brute force passwords, Deploying off-the-shelf malware
personally identifiable information (PII)	Cybercriminals	Selling stolen data, extortion	Phishing emails or malware infections installing ransomware
personally identifiable information (PII)	Insider Threats	revenge, Financial incentives from competitors, leverage	downloading on personal device, sharing login credentials, deleting or sabotaging
personally identifiable information (PII)	Advanced Persiste…	long term access to personal material	custom malware, supply chain attacks, zero day exploits

Complete the 👑 **Key Assets sheet** first to pre-populate this column's dropdown!		*Why* might this TA be motivated to access this asset?	*How* might we expect this TA to attack this asset?
4.1.2 👑 Key Assets	4.1.4 🥷 **Threat Actors**	4.1.4 Motivations ("why")	4.1.4 Typical attacks ("how")

Complete the 👑 **Key Assets sheet** first to pre-populate this column's dropdown!		*Why* might this TA be motivated to access this asset?	*How* might we expect this TA to attack this asset?
4.1.2 👑 Key Assets	4.1.4 🥷 **Threat Actors**	4.1.4 Motivations ("why")	4.1.4 Typical attacks ("how")

Complete the 👑 **Key Assets sheet** first to pre-populate this column's dropdown!		*Why* might this TA be motivated to access this asset?	*How* might we expect this TA to attack this asset?
4.1.2 👑 Key Assets	4.1.4 🥷 **Threat Actors**	4.1.4 Motivations ("why")	4.1.4 Typical attacks ("how")

Complete the 👑 **Key Assets sheet** first to pre-populate this column's dropdown!		*Why* might this TA be motivated to access this asset?	*How* might we expect this TA to attack this asset?
4.1.2 👑 Key Assets	4.1.4 🥷 **Threat Actors**	4.1.4 Motivations ("why")	4.1.4 Typical attacks ("how")

Complete the 👑 **Key Assets sheet** first to pre-populate this column's dropdown!		*Why* might this TA be motivated to access this asset?	*How* might we expect this TA to attack this asset?
4.1.2 👑 Key Assets	4.1.4 🥷 **Threat Actors**	4.1.4 Motivations ("why")	4.1.4 Typical attacks ("how")

Complete the 👑 **Key Assets sheet** first to pre-populate this column's dropdown!		*Why* might this TA be motivated to access this asset?	*How* might we expect this TA to attack this asset?
4.1.2 👑 Key Assets	4.1.4 🥷 **Threat Actors**	4.1.4 Motivations ("why")	4.1.4 Typical attacks ("how")

Complete the 👑 **Key Assets sheet** first to pre-populate this column's dropdown!		*Why* might this TA be motivated to access this asset?	*How* might we expect this TA to attack this asset?
4.1.2 👑 Key Assets	4.1.4 🥷 **Threat Actors**	4.1.4 Motivations ("why")	4.1.4 Typical attacks ("how")

Complete the 👑 **Key Assets sheet** first to pre-populate this column's dropdown!	Name system component here.	Classify this component of the system.	How does this attack surface involve the 👑 Key Asset?	Does this surface connect to any other surfaces?
4.1.2	4.2.1	4.2.1	4.2.1	4.2.1
👑 Key Assets	⚔️ **Attack Surface**	Component type	Relationship	Related surfaces
In-game private chat system	encryption	Software	if end to end isn't configured properly could leak information	gamers messages chat system network traffic
In-game private chat system	gamers	People	could leak credentials through targeted attacks	encryption messages chat system network traffic
In-game private chat system	messages	Data	sensitive private messages	encryption gamers chat system network traffic
In-game private chat system	chat system	Software	software running chat system	encryption gamers messages network traffic
Intellectual property (IP)	.git folder	Data	direct access to game source code	development server API server git hub VPN system credentials database developers laptops network traffic
Intellectual property (IP)	development server	Hardware	IP is stored on the server	.git folder API server git hub VPN system credentials database developers laptops network traffic
Intellectual property (IP)	API server	Hardware	IP data flowing through server	.git folder development server git hub VPN system credentials database developers laptops network traffic
Intellectual property (IP)	git hub	Software	github restrict source code	.git folder development server API server VPN system credentials database developers laptops network traffic
Intellectual property (IP)	VPN system	Software	software running VPN	.git folder development server API server git hub creditials database developers laptops network traffic
Intellectual property (IP)	developers	People	have personal knowledge and credentials to source code	.git folder development server API server git hub VPN system credentials database laptops network traffic
Intellectual property (IP)	laptops	Hardware	contains credentials to IP	.git folder development server API server git hub VPN system credentials database network traffic developers
Intellectual property (IP) personally identifiable information (PII) Payment information (PCI)	credentials database	Data	holds credential information for IP, PII, and PCI	.git folder development server API server git hub VPN system payment processing server encryption gamers developers laptops employees PCI PCI software messages chat system network traffic
Payment information (PCI)	payment processing server	Hardware	PCI data	credentials database employees PCI PCI software network traffic
Payment information (PCI)	gamers	People	use PCI system	credentials database payment processing server employees PCI PCI software network traffic
Payment information (PCI)	employees	People	have credentials for PCI	credentials database payment processing server PCI PCI software network traffic gamers

Complete the 👑 **Key Assets sheet** first to pre-populate this column's dropdown!	Name system component here.	Classify this component of the system.	How does this attack surface involve the 👑 Key Asset?	Does this surface connect to any other surfaces?
4.1.2	4.2.1	4.2.1	4.2.1	4.2.1
👑 Key Assets	⚔️ **Attack Surface**	Component type	Relationship	Related surfaces
Payment information (PCI)	PCI	Data	PCI data	credentials database payment processing server employees PCI software network traffic gamers
Payment information (PCI)	PCI software	Software	corruptible software for PCI	credentials database payment processing server employees PCI gamers network traffic
Payment information (PCI) personally identifiable information (PII) In-game private chat system	network traffic	Data	entire flow of sensitive traffic	chat system messages PCI software PCI employees laptops developers gamers encryption payment processing server credentials database VPN system git hub API server development server .git folder

Complete the 👑 **Key Assets sheet** first to pre-populate this column's dropdown!	Name system component here.	Classify this component of the system.	How does this attack surface involve the 👑 Key Asset?	Does this surface connect to any other surfaces?
4.1.2	4.2.1	4.2.1	4.2.1	4.2.1
👑 Key Assets	⚔️ **Attack Surface**	Component type	Relationship	Related surfaces

Complete the 👑 **Key Assets sheet** first to pre-populate this column's dropdown!	Name system component here.	Classify this component of the system.	How does this attack surface involve the 👑 Key Asset?	Does this surface connect to any other surfaces?
4.1.2	4.2.1	4.2.1	4.2.1	4.2.1
👑 Key Assets	⚔️ **Attack Surface**	Component type	Relationship	Related surfaces

Complete the 👑 **Key Assets sheet** first to pre-populate this column's dropdown!	Name system component here.	Classify this component of the system.	How does this attack surface involve the 👑 Key Asset?	Does this surface connect to any other surfaces?
4.1.2	4.2.1	4.2.1	4.2.1	4.2.1
👑 Key Assets	⚔️ **Attack Surface**	Component type	Relationship	Related surfaces

Complete the 👑 **Key Assets sheet** first to pre-populate this column's dropdown!	Name system component here.	Classify this component of the system.	How does this attack surface involve the 👑 Key Asset?	Does this surface connect to any other surfaces?
4.1.2	4.2.1	4.2.1	4.2.1	4.2.1
👑 Key Assets	⚔️ **Attack Surface**	Component type	Relationship	Related surfaces

Complete the 👑 **Key Assets sheet** first to pre-populate this column's dropdown!	Name system component here.	Classify this component of the system.	How does this attack surface involve the 👑 Key Asset?	Does this surface connect to any other surfaces?
4.1.2	4.2.1	4.2.1	4.2.1	4.2.1
👑 Key Assets	⚔️ **Attack Surface**	Component type	Relationship	Related surfaces

Complete the ⚔ **Attack Surface sheet** first to pre-populate this column's dropdown!	List anything that could go wrong with this ⚔ Attack Surface	What is the likelihood of this 🔒 Risk being exploited?	What is the impact if this 🔒 Risk were successfully exploited?	Add likelihood and impact ratings together.
4.2.1	4.2.2	4.2.2	4.2.2	4.2.2
⚔ Attack Surface	🔒 **Risks**	Likelihood	Impact	Rating
encryption	TA manipulates end to end encryption key	1 (Rare)	4 (Major)	5
gamers	gamers could leak credentials through targeted attacks	4 (Likely)	3 (Moderate)	7
messages	messages could be intercepted in in game chat	3 (Possible)	3 (Moderate)	6
chat system	TA hacks chat system OS	2 (Unlikely)	3 (Moderate)	5
.git folder	TA has access to game code	5 (Almost Certai…	4 (Major)	9
development server	TA steals IP	4 (Likely)	4 (Major)	8
API server	TA gains access to API server	3 (Possible)	5 (Catastrophic)	8
git hub	TA gains access to all game source code	4 (Likely)	4 (Major)	8
VPN system	VPN system is hacked allowing lateral movement	3 (Possible)	4 (Major)	7
developers	Developers could use their credentials to sabotage	2 (Unlikely)	4 (Major)	6
laptops	laptops could get stolen	3 (Possible)	4 (Major)	7
credentials database	credentials database hacked	4 (Likely)	5 (Catastrophic)	9
payment processing server	PCI server attack	2 (Unlikely)	5 (Catastrophic)	7
employees	employees use their credentials for sabotage or financial gain	2 (Unlikely)	4 (Major)	6
PCI	TA gains access to payment information	2 (Unlikely)	5 (Catastrophic)	7
PCI software	TA manipulates software of PCI system	2 (Unlikely)	5 (Catastrophic)	7
network traffic	TA intercepts network traffic	3 (Possible)	3 (Moderate)	6

Complete the ⚔ **Attack Surface sheet** first to pre-populate this column's dropdown!	List anything that could go wrong with this ⚔ Attack Surface	What is the likelihood of this 🔒 Risk being exploited?	What is the impact if this 🔒 Risk were successfully exploited?	Add likelihood and impact ratings together.
4.2.1	4.2.2	4.2.2	4.2.2	4.2.2
⚔ Attack Surface	🔒 **Risks**	Likelihood	Impact	Rating

Complete the ⚔ **Attack Surface sheet** first to pre-populate this column's dropdown!	List anything that could go wrong with this ⚔ Attack Surface	What is the likelihood of this 🔒 Risk being exploited?	What is the impact if this 🔒 Risk were successfully exploited?	Add likelihood and impact ratings together.
4.2.1	4.2.2	4.2.2	4.2.2	4.2.2
⚔ Attack Surface	🔒 **Risks**	Likelihood	Impact	Rating

Complete the ⚔ **Attack Surface sheet** first to pre-populate this column's dropdown!	List anything that could go wrong with this ⚔ Attack Surface	What is the likelihood of this 🔒 Risk being exploited?	What is the impact if this 🔒 Risk were successfully exploited?	Add likelihood and impact ratings together.
4.2.1	4.2.2	4.2.2	4.2.2	4.2.2
⚔ Attack Surface	🔒 **Risks**	Likelihood	Impact	Rating

Complete the ⚔ **Attack Surface sheet** first to pre-populate this column's dropdown!	List anything that could go wrong with this ⚔ Attack Surface	What is the likelihood of this 🔒 Risk being exploited?	What is the impact if this 🔒 Risk were successfully exploited?	Add likelihood and impact ratings together.
4.2.1	4.2.2	4.2.2	4.2.2	4.2.2
⚔ Attack Surface	🔒 **Risks**	Likelihood	Impact	Rating

Complete the ⚔ **Attack Surface sheet** first to pre-populate this column's dropdown!	List anything that could go wrong with this ⚔ Attack Surface	What is the likelihood of this 🔒 Risk being exploited?	What is the impact if this 🔒 Risk were successfully exploited?	Add likelihood and impact ratings together.
4.2.1	4.2.2	4.2.2	4.2.2	4.2.2
⚔ Attack Surface	🔒 **Risks**	Likelihood	Impact	Rating

Complete the ⚔ **Attack Surface sheet** first to pre-populate this column's dropdown!	List anything that could go wrong with this ⚔ Attack Surface	What is the likelihood of this 🔒 Risk being exploited?	What is the impact if this 🔒 Risk were successfully exploited?	Add likelihood and impact ratings together.
4.2.1	4.2.2	4.2.2	4.2.2	4.2.2
⚔ Attack Surface	🔒 **Risks**	Likelihood	Impact	Rating

Complete the ⚔ **Attack Surface sheet** first to pre-populate this column's dropdown!	List anything that could go wrong with this ⚔ Attack Surface	What is the likelihood of this 🔒 Risk being exploited?	What is the impact if this 🔒 Risk were successfully exploited?	Add likelihood and impact ratings together.
4.2.1	4.2.2	4.2.2	4.2.2	4.2.2
⚔ Attack Surface	🔒 **Risks**	Likelihood	Impact	Rating

Complete the Risks sheet first to pre-populate this column's dropdown!	List any TTPs that might be involved in this Risk.	Add the URL to this particular ATT&CK TTP.	Note how this TTP relates to this Risk.	Imagine a scenario where a Threat Actor might use this TTP.
4.2.2	4.2.4	4.2.4	4.2.4	4.2.4
Risks	**Attack Vectors**	ATT&CK TTP URL	Relevance	Scenarios
TA manipulates end to end encryption key	T1555.03: Credentials from Web Browsers	https://attack.mitre.org/techniques/T1555/003/	Adversaries may acquire credentials from web browsers by reading files specific to the target browser.	TA use encryption key to spy in on game chat.
gamers could leak credentials through targeted attacks	T1003: Credential Dumping	https://attack.mitre.org/techniques/T1003/	Adversaries may attempt to dump credentials to obtain account login and credential material, normally in the form of a hash or a clear text password.	TA optains gamers credentials to log into accounts
messages could be intercepted in in game chat	T1557: Adversary-in-the-Middle	https://attack.mitre.org/techniques/T1557/	Adversaries may attempt to position themselves between two or more networked devices using an adversary-in-the-middle	TA intercepts message traffic to obtain private information
TA hacks chat system OS	T1190: Exploit Public-Facing Application	https://attack.mitre.org/techniques/T1190/	Adversaries may attempt to exploit a weakness in an Internet-facing host or system to initially access a network.	TA exploits weakness in the system that can be a software bug, a temporary glitch, or a misconfiguration.
TA has access to game code	T1505: Server Software Component	https://attack.mitre.org/techniques/T1505/	Adversaries may abuse legitimate extensible development features of servers to establish persistent access to systems.	TA uses source code to inject malicious code.
TA steals IP	T1005: Data from Local System	https://attack.mitre.org/techniques/T1005/	Adversaries may search local system sources, such as file systems, configuration files, local databases, or virtual machine files, to find files of interest and sensitive data prior to Exfiltration.	TA extracts source code to sell or manipulate.
TA gains access to API server	T1078: Valid Accounts	https://attack.mitre.org/techniques/T1078/	Adversaries may obtain and abuse credentials of existing accounts as a means of gaining Initial Access, Persistence, Privilege Escalation, or Defense Evasion.	TA uses valid account credentials to access API
TA gains access to all game source code	T1649: Steal or Forge Authentication Certificates	https://attack.mitre.org/techniques/T1649/	Adversaries may steal or forge certificates used for authentication to access remote systems or resources.	TA accesses restricted Git folders to manipulate or steal source code
VPN system is hacked allowing lateral movement	T1199: Trusted Relationship	https://attack.mitre.org/techniques/T1199/	Access through trusted third party relationship abuses an existing connection that may not be protected or receives less scrutiny than standard mechanisms of gaining access to a network.	TA uses third party access to allow entry into network for lateral movement.
Developers could use their creditals to sabatoge	T1609: Container Administration Command	https://attack.mitre.org/techniques/T1609/	Adversaries may abuse a container administration service to execute commands within a container	TA uses back door access provided by a developer during original source code development
laptops could get stolen	T1555: Credentials from Password Stores	https://attack.mitre.org/techniques/T1555/	Adversaries may search for common password storage locations to obtain user credentials.	TA uses stolen laptop data to provide user credentials
credentials database hacked	T1003: Credential Dumping	https://attack.mitre.org/techniques/T1003/	Adversaries may attempt to dump credentials to obtain account login and credential material, normally in the form of a hash or a clear text password.	TA gains access to credential database to use for escalation
PCI server attack	T1190: Exploit Public-Facing Application	https://attack.mitre.org/techniques/T1190/	Adversaries may attempt to exploit a weakness in an Internet-facing host or system to initially access a network.	TA eploits a weakness in host allowing access to server and PCI information.
employees use thier creditials for sabatoge or finacial gain	T1078: Valid Accounts	https://attack.mitre.org/techniques/T1078/	Adversaries may obtain and abuse credentials of existing accounts as a means of gaining Initial Access, Persistence, Privilege Escalation, or Defense Evasion.	TA, typically insider threat, uses valid credentials to steal credit card information

Complete the **Risks sheet** first to pre-populate this column's dropdown!	List any TTPs that might be involved in this **Risk.**	Add the URL to this particular ATT&CK TTP.	Note how this TTP relates to this **Risk.**	Imagine a scenario where a **Threat Actor** might use this TTP.
4.2.2	4.2.4	4.2.4	4.2.4	4.2.4
Risks	**Attack Vectors**	ATT&CK TTP URL	Relevance	Scenarios
TA gains access to payment information	T1555: Credentials from Password Stores	https://attack.mitre.org/techniques/T1555/	Adversaries may search for common password storage locations to obtain user credentials.	TA can sell or use financial information
TA manipulates software of PCI system	T1609: Container Administration Command	https://attack.mitre.org/techniques/T1609/	Adversaries may abuse a container administration service to execute commands within a container.	TA manipulates software on PCI system to allow future access.
TA intercepts network traffic	T1040: Network Sniffing	https://attack.mitre.org/techniques/T1040/	Adversaries may passively sniff network traffic to capture information about an environment, including authentication material passed over the network.	TA intercepts message traffic to obtain private information

Complete the **Risks sheet** first to pre-populate this column's dropdown!	List any TTPs that might be involved in this **Risk.**	Add the URL to this particular ATT&CK TTP.	Note how this TTP relates to this **Risk.**	Imagine a scenario where a **Threat Actor** might use this TTP.
4.2.2	4.2.4	4.2.4	4.2.4	4.2.4
Risks	**Attack Vectors**	ATT&CK TTP URL	Relevance	Scenarios

Complete the **Risks sheet** first to pre-populate this column's dropdown!	List any TTPs that might be involved in this **Risk.**	Add the URL to this particular ATT&CK TTP.	Note how this TTP relates to this **Risk.**	Imagine a scenario where a **Threat Actor** might use this TTP.
4.2.2	4.2.4	4.2.4	4.2.4	4.2.4
Risks	**Attack Vectors**	ATT&CK TTP URL	Relevance	Scenarios

Complete the **Risks sheet** first to pre-populate this column's dropdown!	List any TTPs that might be involved in this **Risk.**	Add the URL to this particular ATT&CK TTP.	Note how this TTP relates to this **Risk.**	Imagine a scenario where a **Threat Actor** might use this TTP.
4.2.2	4.2.4	4.2.4	4.2.4	4.2.4
Risks	**Attack Vectors**	ATT&CK TTP URL	Relevance	Scenarios

Complete the **Risks sheet** first to pre-populate this column's dropdown!	List any TTPs that might be involved in this **Risk.**	Add the URL to this particular ATT&CK TTP.	Note how this TTP relates to this **Risk.**	Imagine a scenario where a **Threat Actor** might use this TTP.
4.2.2	4.2.4	4.2.4	4.2.4	4.2.4
Risks	**Attack Vectors**	ATT&CK TTP URL	Relevance	Scenarios

Title of your attack scenario. 4.2.5 **Attack Scenario**	Complete the **Attack Vectors sheet** first to pre-populate this column's dropdown! 4.2.4 Attack Vectors	Describe in detail a scenario chaining these TTPs together to result in TA accessing **Key Asset.** 4.2.5 Details
Exploited public facing applications	T1190: Exploit Public-Facing Appli… T1078: Valid Accounts T1005: Data from Local System	An attacker exploits a vulnerability on a public-facing web server.The attacker uses stolen credentials to access the vendor's development environment.They locate and exfiltrate sensitive data.
Insider threat	T1078: Valid Accounts T1005: Data from Local System	A company employee uses credentials to download company IP and sell it to competitors.
Malware financial attack	T1649: Steal or Forge Authenticati… T1505: Server Software Component T1005: Data from Local System	TA uses source code gathered from .git folder to inject malware. Malware steals credit card information.
Network sniffing for IP	T1040: Network Sniffing T1078: Valid Accounts T1005: Data from Local System	The attacker gains access to a network segment and begins passively capturing network traffic. The attacker identifies a user's credentials from the sniff network traffic. Using the compromised credentials, and accesses sensitive IP data.

Title of your attack scenario. 4.2.5 **Attack Scenario**	Complete the **Attack Vectors sheet** first to pre-populate this column's dropdown! 4.2.4 Attack Vectors	Describe in detail a scenario chaining these TTPs together to result in TA accessing **Key Asset.** 4.2.5 Details

Title of your attack scenario. 4.2.5 **Attack Scenario**	Complete the **Attack Vectors sheet** first to pre-populate this column's dropdown! 4.2.4 Attack Vectors	Describe in detail a scenario chaining these TTPs together to result in TA accessing **Key Asset.** 4.2.5 Details

Title of your attack scenario. 4.2.5 **Attack Scenario**	Complete the **Attack Vectors sheet** first to pre-populate this column's dropdown! 4.2.4 Attack Vectors	Describe in detail a scenario chaining these TTPs together to result in TA accessing **Key Asset.** 4.2.5 Details

Title of your attack scenario. 4.2.5 **Attack Scenario**	Complete the **Attack Vectors sheet** first to pre-populate this column's dropdown! 4.2.4 Attack Vectors	Describe in detail a scenario chaining these TTPs together to result in TA accessing **Key Asset.** 4.2.5 Details

Title of your attack scenario. 4.2.5 **Attack Scenario**	Complete the **Attack Vectors sheet** first to pre-populate this column's dropdown! 4.2.4 Attack Vectors	Describe in detail a scenario chaining these TTPs together to result in TA accessing **Key Asset.** 4.2.5 Details

Title of your attack scenario. 4.2.5 **Attack Scenario**	Complete the **Attack Vectors sheet** first to pre-populate this column's dropdown! 4.2.4 Attack Vectors	Describe in detail a scenario chaining these TTPs together to result in TA accessing **Key Asset.** 4.2.5 Details

Title of your attack scenario. 4.2.5 🎭 **Attack Scenario**	Complete the 🚪 **Attack Vectors sheet** first to pre-populate this column's dropdown! 4.2.4 🚪 Attack Vectors	Describe in detail a scenario chaining these TTPs together to result in TA accessing 👑 **Key Asset.** 4.2.5 Details

Complete the Attack Vectors sheet first to pre-populate this column's dropdown!	List detective or preventive solutions associated with TTP.					
4.2.4	4.3.2 · 4.3.5 · 4.3.8	4.4.x	4.4.x	4.4.x	4.4.x	4.4.x
Attack Vectors	**Solution**	Solution type	Keep?	URL	Description	Milestones
T1555.03: Credentials from Web Browsers	DS0009: Process	DETECTIVE: Data source	YES	https://attack.mitre.org/datasources/DS0009/#OS%20API%20Executio	Monitor for API calls that may acquire credentials from web browsers by reading files specific to the target browser.[1] Analytic 1 - Suspicious API calls related to web browser credential access. index=security sourcetype IN ("WinEventLog:Microsoft-Windows-Sysmon/Operational", "linux_secure", "macos_secure") event_type="api_call"(api IN ("CryptUnprotectData", "NSS_Init", "PK11SDR_Decrypt", "SecItemCopyMatching", "SecItemAdd", "SecItemUpdate", "SecItemDelete"))	(exists) (ingest into SIEM) (validate alerts)
T1005: Data from Local System	DS0009:Process	DETECTIVE: Data source	YES	https://attack.mitre.org/datasources/DS0009/	Monitor for API calls that may search local system sources, such as file systems or local databases, to find files of interest and sensitive data prior to Exfiltration.	(ingest into SIEM) (validate alerts) (exists)
T1040: Network Sniffing	DS0009:Process	DETECTIVE: Data source	YES	https://attack.mitre.org/datasources/DS0009/	Monitor for API calls that may search local system sources, such as file systems or local databases, to find files of interest and sensitive data prior to Exfiltration.	(exists) (already ingested to SIEM) (validate alerts)
T1557: Adversary-in-the-Middle	DS0015: Application Log	DETECTIVE: Data source	YES	https://attack.mitre.org/datasources/DS0015/	Monitor application logs for changes to settings and other events associated with network protocols and other services commonly abused for AiTM.[17]	(create) (ingest into SIEM)
T1190: Exploit Public-Facing Application	DS0015: Application Log	DETECTIVE: Data source	YES	https://attack.mitre.org/datasources/DS0015/	Monitor application logs for changes to settings and other events associated with network protocols and other services commonly abused for AiTM.[17]	(exists) (already ingested to SIEM) (configure alerts) (validate alerts)
T1199: Trusted Relationship	DS0015: Application Log	DETECTIVE: Data source	YES	https://attack.mitre.org/datasources/DS0015/	Configuration management databases (CMDB) and other asset management systems may help with the detection of computer systems or network devices that should not exist on a network. Monitor logs for unexpected actions taken by any delegated administrator accounts.	(create) (ingest into SIEM)
T1609: Container Administration Comma…	DS0017: Command	DETECTIVE: Data source	YES	https://attack.mitre.org/datasources/DS0017/	Monitor command execution within containers to detect suspicious activity. Commands executed via Docker (docker exec) or Kubernetes (kubectl exec) should be captured along with relevant metadata. Analytic 1 - Unusual command executions in container services sourcetype=docker:daemon OR sourcetype=kubernetes:apiserver| search command IN ("docker exec", "kubectl exec")	(create) (ingest into SIEM)
T1555: Credentials from Password Stores	DS0017: Command	DETECTIVE: Data source	YES	https://attack.mitre.org/datasources/DS0017/	Monitor command execution within containers to detect suspicious activity. Commands executed via Docker (docker exec) or Kubernetes (kubectl exec) should be captured along with relevant metadata. Analytic 1 - Unusual command executions in container services sourcetype=docker:daemon OR sourcetype=kubernetes:apiserver| search command IN ("docker exec", "kubectl exec")	(create) (ingest into SIEM)
T1505: Server Software Component	DS0022: File	DETECTIVE: Data source	NO	https://attack.mitre.org/datasources/DS0022/	Consider monitoring file locations associated with the installation of new application software components such as paths from which applications typically load such extensible components.	(create) (ingest into SIEM)
T1649: Steal or Forge Authentication Cer…	DS0026: Active Directory	DETECTIVE: Data source	NO	https://attack.mitre.org/datasources/DS0026/	Monitor AD CS certificate requests (ex: EID 4886) as well as issued certificates (ex: EID 4887) for abnormal activity, including unexpected certificate enrollments and signs of abuse within certificate attributes (such as abusable EKUs)	(create) (ingest into SIEM)
T1078: Valid Accounts	DS0028: Logon Session	DETECTIVE: Data source	NO	https://attack.mitre.org/datasources/DS0028/	Monitor for newly constructed logon behavior that may obtain and abuse credentials of existing accounts as a means of gaining Initial Access, Persistence, Privilege Escalation, or Defense Evasion. Correlate other security systems with login information (e.g., a user has an active login session but has not entered the building or does not have VPN access). sourcetype="WinEventLog:Security" EventCode=4624 | stats count by _time, user, src_ip, dest_ip, LogonType| where LogonType IN ("2", "10") // Interactive or RDP logon| eval is_suspicious=if(src_ip!="expected_ip", "True", "False")| where is_suspicious="True"| table _time, user, src_ip, dest_ip, LogonType	(already ingested to SIEM) (exists) (configure alerts) (validate alerts)

Complete the Attack Vectors sheet first to pre-populate this column's dropdown!	List detective or preventive solutions associated with TTP.					
4.2.4	4.3.2 · 4.3.5 · 4.3.8	4.4.x	4.4.x	4.4.x	4.4.x	4.4.x
Attack Vectors	**Solution**	Solution type	Keep?	URL	Description	Milestones
T1003: Credential Dumping	DS0029: Network Traffic	DETECTIVE: Data source	NO	https://attack.mitre.org/datasources/DS0029/	Monitor for network protocols [33] [38] and other replication requests [37] from IPs not associated with known domain controllers. [23] Analytic 1 - Anomalous network traffic content related to credential managers index=network sourcetype="stream:tcp" dest_port=389 NOT [| inputlookup known_dc_ip_addresses | fields ip]| eval SourceIP = src_ip, DestinationIP = dest_ip, Protocol = proto| search (content="LDAPSearchRequest") OR (content="LDAPModifyRequest") OR (content="bindRequest") OR (content="searchResEntry") OR (content="NTDS.dit")	(exists) (already ingested to SIEM) (validate alerts)
T1078: Valid Accounts	M1013: Application Developer Guidance	PREVENTIVE: Mitigation	NO	https://attack.mitre.org/mitigations/M1013/	Ensure that applications do not store sensitive data or credentials insecurely. (e.g. plaintext credentials in code, published credentials in repositories, or credentials in public cloud storage).	(implement) (validate) (maintain)
T1003: Credential Dumping T1078: Valid Accounts T1649: Steal or Forge Authentication Cer…	M1015: Active Directory Configuration	PREVENTIVE: Mitigation	YES	https://attack.mitre.org/mitigations/M1015/	Manage the access control list for "Replicating Directory Changes All" and other permissions associated with domain controller replication. [23] [24] Consider adding users to the "Protected Users" Active Directory security group. This can help limit the caching of users' plaintext credentials.[	(implement) (validate) (maintain)
T1190: Exploit Public-Facing Application	M1016: Vulnerability Scanning	PREVENTIVE: Mitigation	NO	https://attack.mitre.org/mitigations/M1016/	Regularly scan externally facing systems for vulnerabilities and establish procedures to rapidly patch systems when critical vulnerabilities are discovered through scanning and through public disclosure.[10	(implement) (validate) (maintain)
T1555.03: Credentials from Web Browsers T1003: Credential Dumping T1557: Adversary-in-the-Middle T1078: Valid Accounts	M1017: User Training	PREVENTIVE: Mitigation	YES	https://attack.mitre.org/mitigations/M1017/	Provide user training on secure practices for managing credentials, including avoiding storing sensitive passwords in browsers and using password managers securely. Users should also be educated on identifying phishing attempts that could steal session cookies or credentials.	(implement) (validate) (maintain)
T1505: Server Software Component T1078: Valid Accounts T1199: Trusted Relationship T1609: Container Administration Comma… T1040: Network Sniffing	M1018: User Account Management	PREVENTIVE: Mitigation	YES	https://attack.mitre.org/mitigations/M1018/	Enforce the principle of least privilege by limiting privileges of user accounts so only authorized accounts can modify and/or add server software components.	(implement) (validate) (maintain)
T1555.03: Credentials from Web Browsers	M1021: Restrict Web-Based Content	PREVENTIVE: Mitigation	NO	https://attack.mitre.org/mitigations/M1021/	Restrict or block web-based content that could be used to extract session cookies or credentials stored in browsers. Use browser security settings, such as disabling third-party cookies and restricting browser extensions, to limit the attack surface.	(implement) (validate) (maintain)
T1505: Server Software Component	M1024: Restrict Registry Permissions	PREVENTIVE: Mitigation	NO	https://attack.mitre.org/mitigations/M1024/	Consider using Group Policy to configure and block modifications to service and other critical server parameters in the Registry.	(implement) (validate) (maintain)
T1003: Credential Dumping	M1025: Privileged Process Integrity	PREVENTIVE: Mitigation	NO	https://attack.mitre.org/mitigations/M1025/	On Windows 8.1 and Windows Server 2012 R2, enable Protected Process Light for LSA.[	(implement) (validate) (maintain)
T1003: Credential Dumping T1190: Exploit Public-Facing Application T1505: Server Software Component T1078: Valid Accounts T1609: Container Administration Comma… T1555: Credentials from Password Stores	M1026: Privileged Account Management	PREVENTIVE: Mitigation	YES	https://attack.mitre.org/mitigations/M1026/	Windows:Do not put user or admin domain accounts in the local administrator groups across systems unless they are tightly controlled, as this is often equivalent to having a local administrator account with the same password on all systems. Follow best practices for design and administration of an enterprise network to limit privileged account use across administrative tiers.[31] Linux:Scraping the passwords from memory requires root privileges. Follow best practices in restricting access to privileged accounts to avoid hostile programs from accessing such sensitive regions of memory.	(implement) (validate) (maintain)
T1555.03: Credentials from Web Browsers T1003: Credential Dumping T1078: Valid Accounts T1555: Credentials from Password Stores	M1027: Password Policies	PREVENTIVE: Mitigation	YES	https://attack.mitre.org/mitigations/M1027/	Organizations may consider weighing the risk of storing credentials in web browsers. If web browser credential disclosure is a significant concern, technical controls, policy, and user training may be used to prevent storage of credentials in web browsers.	(implement) (validate) (maintain)
T1003: Credential Dumping	M1028: Operating System Configuration	PREVENTIVE: Mitigation	NO	https://attack.mitre.org/mitigations/M1028/	Consider disabling or restricting NTLM.[29] Consider disabling WDigest authentication.[30]	(implement) (validate) (maintain)
T1557: Adversary-in-the-Middle T1190: Exploit Public-Facing Application T1199: Trusted Relationship T1040: Network Sniffing	M1030: Network Segmentation	PREVENTIVE: Mitigation	YES	https://attack.mitre.org/mitigations/M1030/	Network segmentation can be used to isolate infrastructure components that do not require broad network access. This may mitigate, or at least alleviate, the scope of AiTM activity.	(exists) (maintain)
T1557: Adversary-in-the-Middle	M1031: Network Intrusion Prevention	PREVENTIVE: Mitigation	NO	https://attack.mitre.org/mitigations/M1031/	Network intrusion detection and prevention systems that can identify traffic patterns indicative of AiTM activity can be used to mitigate activity at the network level.	(implement) (validate) (maintain)

Complete the Attack Vectors sheet first to pre-populate this column's dropdown!	List detective or preventive solutions associated with TTP.					
4.2.4	4.3.2 · 4.3.5 · 4.3.8	4.4.x	4.4.x	4.4.x	4.4.x	4.4.x
Attack Vectors	**Solution**	Solution type	Keep?	URL	Description	Milestones
T1078: Valid Accounts T1199: Trusted Relationship T1040: Network Sniffing	M1032: Multi-factor Authentication	PREVENTIVE: Mitigation	YES	https://attack.mitre.org/mitigations/M1032/	Implement multi-factor authentication (MFA) across all account types, including default, local, domain, and cloud accounts, to prevent unauthorized access, even if credentials are compromised. MFA provides a critical layer of security by requiring multiple forms of verification beyond just a password. This measure significantly reduces the risk of adversaries abusing valid accounts to gain initial access, escalate privileges, maintain persistence, or evade defenses within your network.	(implement) (validate) (maintain)
T1557: Adversary-in-the-Middle T1190: Exploit Public-Facing Application T1609: Container Administration Comma…	M1035: Limit Access to Resource Over Network	PREVENTIVE: Mitigation	YES	https://attack.mitre.org/mitigations/M1035/	Limit access to network infrastructure and resources that can be used to reshape traffic or otherwise produce AiTM conditions.	(implement) (validate) (maintain)
T1078: Valid Accounts	M1036: Account Use Policies	PREVENTIVE: Mitigation	NO	https://attack.mitre.org/mitigations/M1036/	Use conditional access policies to block logins from non-compliant devices or from outside defined organization IP ranges.	(implement) (validate) (maintain)
T1557: Adversary-in-the-Middle	M1037: Filter Network Traffic	PREVENTIVE: Mitigation	NO	https://attack.mitre.org/mitigations/M1037/	Use network appliances and host-based security software to block network traffic that is not necessary within the environment, such as legacy protocols that may be leveraged for AiTM conditions.	(implement) (validate) (maintain)
T1609: Container Administration Comma…	M1038: Execution Prevention	PREVENTIVE: Mitigation	NO	https://attack.mitre.org/mitigations/M1038/	Use read-only containers, read-only file systems, and minimal images when possible to prevent the execution of commands.[11] Where possible, also consider using application control and software restriction tools (such as those provided by SELinux) to restrict access to files, processes, and system calls in containers.	(implement) (validate) (maintain)
T1003: Credential Dumping	M1040: Behavior Prevention on Endpoint	PREVENTIVE: Mitigation	NO	https://attack.mitre.org/mitigations/M1040/	On Windows 10, enable Attack Surface Reduction (ASR) rules to secure LSASS and prevent credential stealing. [26]	(implement) (validate) (maintain)
T1003: Credential Dumping T1557: Adversary-in-the-Middle T1649: Steal or Forge Authentication Cer… T1040: Network Sniffing	M1041: Encrypt Sensitive Information	PREVENTIVE: Mitigation	YES	https://attack.mitre.org/mitigations/M1041/	Ensure Domain Controller backups are properly secured.	(implement) (validate) (maintain)
T1557: Adversary-in-the-Middle T1505: Server Software Component T1649: Steal or Forge Authentication Cer… T1609: Container Administration Comma…	M1042: Disable or Remove Feature or Program	PREVENTIVE: Mitigation	YES	https://attack.mitre.org/mitigations/M1042/	Disable legacy network protocols that may be used to intercept network traffic if applicable, especially those that are not needed within an environment.	(implement) (validate) (maintain)
T1003: Credential Dumping	M1043: Credential Access Protection	PREVENTIVE: Mitigation	NO	https://attack.mitre.org/mitigations/M1043/	With Windows 10, Microsoft implemented new protections called Credential Guard to protect the LSA secrets that can be used to obtain credentials through forms of credential dumping. It is not configured by default and has hardware and firmware system requirements. [27] It also does not protect against all forms of credential dumping.	(implement) (validate) (maintain)
T1505: Server Software Component	M1045: Code Signing	PREVENTIVE: Mitigation	NO	https://attack.mitre.org/mitigations/M1045/	Ensure all application component binaries are signed by the correct application developers	(implement) (maintain) (validate)
T1505: Server Software Component	M1046: Boot Integrity	PREVENTIVE: Mitigation	NO	https://attack.mitre.org/mitigations/M1046/	Enabling secure boot allows validation of software and drivers during initial system boot.	(implement) (validate) (maintain)
T1505: Server Software Component T1649: Steal or Forge Authentication Cer…	M1047: Audit	PREVENTIVE: Mitigation	YES	https://attack.mitre.org/mitigations/M1047/	Regularly check component software on critical services that adversaries may target for persistence to verify the integrity of the systems and identify if unexpected changes have been made.	(implement) (validate) (maintain)
T1190: Exploit Public-Facing Application	M1048: Application Isolation and Sandboxing	PREVENTIVE: Mitigation	NO	https://attack.mitre.org/mitigations/M1048/	Application isolation will limit what other processes and system features the exploited target can access.	(implement) (validate) (maintain)
T1190: Exploit Public-Facing Application	M1050: Exploit Protection	PREVENTIVE: Mitigation	NO	https://attack.mitre.org/mitigations/M1050/	Web Application Firewalls may be used to limit exposure of applications to prevent exploit traffic from reaching the application.	(implement) (validate) (maintain)
T1555.03: Credentials from Web Browsers T1190: Exploit Public-Facing Application T1555: Credentials from Password Stores	M1051: Update Software	PREVENTIVE: Mitigation	YES	https://attack.mitre.org/mitigations/M1051/	Regularly update web browsers, password managers, and all related software to the latest versions. Keeping software up-to-date reduces the risk of vulnerabilities being exploited by attackers to extract stored credentials or session cookies.	(implement) (validate) (maintain)
T1005: Data from Local System	M1057: Data Loss Prevention	PREVENTIVE: Mitigation	NO	https://attack.mitre.org/mitigations/M1057/	Data loss prevention can restrict access to sensitive data and detect sensitive data that is unencrypted.	(implement) (validate) (maintain)
T1190: Exploit Public-Facing Application	Web bug on internal web server containing IP	DETECTIVE: Honeypot	YES	https://canarytokens.org/nest/	Detect if a directory enumeration is performed on dev.xibalbainteractive.com (IP)	(create) (ingest alerts into SIEM)
T1557: Adversary-in-the-Middle	Honey token in live game chat	DETECTIVE: Honeypot	YES	https://canarytokens.org/nest/	Detect if in game chat is being viewed by outside threat.	(create) (ingest alerts into SIEM)
T1199: Trusted Relationship	Honey net on VPN	DETECTIVE: Honeypot	YES	https://canarytokens.org/nest/	Detect if advisarey is in network.	(create) (ingest alerts into SIEM)
T1555: Credentials from Password Stores T1609: Container Administration Comma…	Honey creds in credentials server	DETECTIVE: Honeypot	YES	https://canarytokens.org/nest/	Detect if credentials are being viewed for PCI,PII,or IP.	(create) (ingest alerts into SIEM)
T1190: Exploit Public-Facing Application	Honey data in guestbook	DETECTIVE: Honeypot	YES	https://canarytokens.org/nest/	Detect if guestbook source code is being viewed.	(create) (ingest alerts into SIEM)

Complete the **Attack Vectors sheet** first to pre-populate this column's dropdown!	List detective or preventive solutions associated with TTP.					
4.2.4	4.3.2 · 4.3.5 · 4.3.8	4.4.x	4.4.x	4.4.x	4.4.x	4.4.x
Attack Vectors	**Solution**	Solution type	Keep?	URL	Description	Milestones

Complete the **Attack Vectors sheet** first to pre-populate this column's dropdown!	List detective or preventive solutions associated with TTP.					
4.2.4	4.3.2 · 4.3.5 · 4.3.8	4.4.x	4.4.x	4.4.x	4.4.x	4.4.x
Attack Vectors	**Solution**	Solution type	Keep?	URL	Description	Milestones

Complete the **Attack Vectors sheet** first to pre-populate this column's dropdown!	List detective or preventive solutions associated with TTP.					
4.2.4	4.3.2 · 4.3.5 · 4.3.8	4.4.x	4.4.x	4.4.x	4.4.x	4.4.x
Attack Vectors	**Solution**	Solution type	Keep?	URL	Description	Milestones

Complete the Solutions sheet first to pre-populate this column's dropdown!								
4.3.2 · 4.3.5 · 4.3.8	4.4.1	4.4.1	4.4.1	4.4.1	4.4.1	4.4.1	4.4.1	4.4.1
Solution	**Goal**	Specific	Measurable	Achievable	Relevant	Time-bound	Checklist	Formal Deadline
DS0009:Process	Push data source to SIEM	Deploy EDR within all one month push to SIEM	Success is measured by deployment of tool	implement Endpoint Detection and Response (EDR) Tools in one months	Leverage tools to monitor API execution behaviors at the process level.	One month deadline	☐	
DS0009:Process	Maintain data source.	Schedule EDR audits every month	Collect audits monthly	Conduct EDR audits monthly	Ensure proper API user behavior	Monthly	☐	
DS0009:Process	Identify 100% of malicious API traffic	Identify 100% of malicious API traffic	Allow zero unidentified malicious traffic	Achievable monitoring	Identify all malicious traffic	Target completion three months	☐	
DS0015: Application Log	Implement Application Log Content in two months	Deploy Application Log Content within two months	Successful deployment	Achievable time period	Collect application logs to monitor application traffic	2 months	☐	
DS0015: Application Log	Conduct audits of application logs monthly	Audit logs on a monthly schedule	Collect audits monthly	Achievable time period	Identify all malicious traffic	Monthly	☐	
DS0015: Application Log	Identify 100% of malicious application traffic within 3 months	Identify 100% of malicious application traffic	Allow zero unidentified malicious traffic	Achievable continuous monitoring	Identify all malicious traffic	Target completion three months	☐	
DS0017: Command	Implement Command Execution in two months	Identify when command executions are made	Success is measured by deployment of command execution	two months is a reasonable time frame	Collect logs to monitor command execution	two month deadline	☐	
DS0017: Command	Conduct audits of command logs monthly	Audit logs on a monthly schedule	Track number of logs each month	Achievable time frame	continuous identification of command logs	Monthly	☐	
DS0017: Command	Identify 100% of malicious logs within three months	Identify all malicious logs within three months	Success is measured by not missing any relevant alerts	achievable after implementation	Monitor for malicious commands	Three months	☐	
M1026: Privileged Accou…	Implement RBAC in a month	Use tools like Active Directory Group Policies to enforce access restrictions in a month	Success is measured by by employment success in time period	Achievable	Allow only authority restrictions	One month deadline	☐	
M1026: Privileged Accou…	Allow only privilege access in one month	Allow only privilege access in one month	Success when only privilege access is available	yes	Allows only specific authorization	One month deadline	☐	
M1032: Multi-factor Auth…	Implement MFA for all critical systems	Implement MFA for critical systems in three months	Success when MFA is established in critical systems	goal is realistic timeframe	Better security by validating account users	Three month deadline	☐	
M1032: Multi-factor Auth…	Train all employees on using MFA by the end of the quarter	Train all employees on establishing MFA for logins by end of quarter	Success when all employees are trained	Realistic timeframe for goal	Employees need to be trained on how to set up and use MFA	End of quarter deadline	☐	

Complete the Solutions sheet first to pre-populate this column's dropdown!								
4.3.2 · 4.3.5 · 4.3.8	4.4.1	4.4.1	4.4.1	4.4.1	4.4.1	4.4.1	4.4.1	4.4.1
Solution	**Goal**	Specific	Measurable	Achievable	Relevant	Time-bound	Checklist	Formal Deadline
M1032: Multi-factor Auth…	Achieve 100% compliance for using strong authentication by year-end	All employees need to be utilizing MFA by end of year	Success is measured when 100% of employees are utilizing MFA	One year timeframe for 100% utilization is achievable	100% compliance will ensure better account verification	one year deadline	☐	
M1027: Password Policies	Set and enforce secure password policies by end of quarter	Enforce secure more complicated passwords by end of quarter	When all passwords are updated	All Employees should have passwords updated by end of quarter	more stringent and not reused passwords will make accounts more secure	End of quarter deadline	☐	
M1027: Password Policies	Change passwords every 3 months	Employees will update a new password every month	When all passwords are updated every three months	This is an achievable timeframe to update passwords	Changing passwords every three months will decrease likelihood of reused passwords in system	every three months	☐	
M1042: Disable or Remov…	Disable or Remove Feature or Program in 6 months	Reduce attack surface by removing or disabling programs in 6 months	Reduction of attack surface in 6 months	Achievable to reduce attack surface in 6 months	Reduces attack surface to lessen threat environment	six month deadline	☐	
M1042: Disable or Remov…	Reduce attack surface by 25% in 6 months	Locate and remove older software that no longer updates with patches decreasing attack surface by 25%	When attack surface is reduced by 25%	Finding 25% reduction in attack surface is achievable	Reduces attack surface to lessen threat environment	six month deadline	☐	
Honey creds in credential…	Implement a honey cred in 1 month	Implement a honey cred in credital server in a month	When a working Honey crede is operational in a month	Achievable one month time frame	Get an alert if malicious activity in credential server	one month deadline	☐	
Honey creds in credential…	Test honey cred alert	Test honey cred is working once implemented	Success when alert is triggered correctly	Working alert is achievable	Honey cred must work to be useful	one month deadline	☐	
Web bug on internal web …	implement Web bug on internal server	Implement Web bug on internal web server containing IP in one month	web bug is installed	Implementation is achievable	Get an alert if malicious activity internal server	one month deadline	☐	
Web bug on internal web …	Test web bug	Test web bug is alerting properly after implementation	Success if alert works	Working alert is achievable	web bug must work to be relevant	one month deadline	☐	
							☐	
							☐	
							☐	
							☐	
							☐	
							☐	

Complete the **Solutions sheet** first to pre-populate this column's dropdown!

4.3.2 · 4.3.5 · 4.3.8 Solution	4.4.1 **Goal**	4.4.1 Specific	4.4.1 Measurable	4.4.1 Achievable	4.4.1 Relevant	4.4.1 Time-bound	4.4.1 Checklist	4.4.1 Formal Deadline
							☐	
							☐	
							☐	

Complete the **Solutions sheet** first to pre-populate this column's dropdown!

4.3.2 · 4.3.5 · 4.3.8 Solution	4.4.1 **Goal**	4.4.1 Specific	4.4.1 Measurable	4.4.1 Achievable	4.4.1 Relevant	4.4.1 Time-bound	4.4.1 Checklist	4.4.1 Formal Deadline
							☐	
							☐	
							☐	

Complete the **Solutions sheet** first to pre-populate this column's dropdown!

4.3.2 · 4.3.5 · 4.3.8 Solution	4.4.1 **Goal**	4.4.1 Specific	4.4.1 Measurable	4.4.1 Achievable	4.4.1 Relevant	4.4.1 Time-bound	4.4.1 Checklist	4.4.1 Formal Deadline
							☐	
							☐	
							☐	

Complete the **Solutions sheet** first to pre-populate this column's dropdown!

4.3.2 · 4.3.5 · 4.3.8 Solution	4.4.1 **Goal**	4.4.1 Specific	4.4.1 Measurable	4.4.1 Achievable	4.4.1 Relevant	4.4.1 Time-bound	4.4.1 Checklist	4.4.1 Formal Deadline
							☐	
							☐	
							☐	

Complete the **Solutions sheet** first to pre-populate this column's dropdown!

4.3.2 · 4.3.5 · 4.3.8 Solution	4.4.1 **Goal**	4.4.1 Specific	4.4.1 Measurable	4.4.1 Achievable	4.4.1 Relevant	4.4.1 Time-bound	4.4.1 Checklist	4.4.1 Formal Deadline
							☐	
							☐	
							☐	

Complete the **Solutions sheet** first to pre-populate this column's dropdown!	Which audience do you need to communicate value to?	What risk or issue does solution address?	How does solution solve the problem?	Why is solution effective?	What specific examples or statistics can strengthen your argument?	Why should this stakeholder care?
4.3.2 · 4.3.5 · 4.3.8	4.4.3	4.4.3	4.4.3	4.4.3	4.4.3	4.4.3
Solution	Stakeholder	State the problem	Propose the solution	Explain the benefits	Provide evidence or examples	Summary for specific stakeholder
DS0009:Process	Executives	There are areas in the network that activity could go unnoticed. API servers are one of the more important places to monitor.	Monitoring API logs to detect any odd behavior	Monitoring these logs will provide better security by being able to see what protial threats may be happening.	It would be like setting up more/better security cameras the an office.The better the cameras are able to see everything, the less likely anything goes unnoticed in a blind spot.	Our goal is to provide the best monitoring possible. This specific monitoring is already running on each host, so simply pushing it to an area that could warn the proper people quicker could be done quickly and cheaply.
DS0009:Process	IT Teams	DS0009:Process is stored locally on each host and not currently being pushed to the SIEM:	Push to SIEM.	Monitoring these calls can provide insight into a process's intent, especially if the process is malicious.	Let's say an attacker successfully exploits the XSS vulnerability on the guestbook feature and manages to compromise the API server (api.xibalbagames.com).Attacker could quietly install backdoors, move to other systems, or exfiltrate data	Ingesting these logs should be an easy solution. It would provide valuable feedback on how or if the are any malicious actions are happening. It will be much easier to deal with when an alert is triggered rather than later.
DS0009:Process	Legal/Compliance	Unmonitored API logs could lead to compliance issues	Monitoring process logs will help to secure network and provide documentation	Implementation will address compliance issues related to IP threats.	If a TA was in network using API to extract source code, it would provide documentation in case of audit.	With provided data source implemented it would provide documentation for legal reasons and be compliant with regulations.
DS0015: Application Log	Executives	Better monitoring is needed in the application logs.	Monitoring application logs to detect any odd behavior	Monitoring these logs will provide better security by being able to see what protial threats may be happening.	It would be like setting up more/better security cameras the an office.The better the cameras are able to see everything, the less likely anything goes unnoticed in a blind spot.	Our goal is to provide the best monitoring possible. Monitoring applications would not only increase security, but provide better integrity of our network as a whole.
DS0015: Application Log	IT Teams	Application logs need monitored for malicious activity	These logs may include metrics, errors, performance data, and operational alerts from web, mail, or other applications. These logs are vital for monitoring application behavior and detecting malicious activities or anomalies.	Collecting these logs will help by seeing any malicious activity, reducing the time needed to trace what a TA might have had access to.	Will be able to see if a TA accessed any data in dev.xibalbainteractive.com	This will reduce time and effort into finding potential threats within the network.
DS0015: Application Log	Legal/Compliance	Unmonitored application logs could lead to compliance issues	Monitoring application logs will help to secure network and provide documentation	Implementation will address compliance issues related to IP threats.	If a TA was in network using applications to extract source code, it would provide documentation in case of audit.	With provided data source implemented it would provide documentation for legal reasons and be compliant with regulations. It will provide breach notification and provide a better picture of risk management.
Honey creds in credentials server	Executives	Credentials for everything from payment information to account access are very high value targets.	Set a trap to be alerted if an actor is trying to obtain financial credentials.	It will allow us to be able to respond quicker and provide valuable information about the attacker.	We set up a trap by installing fake credential data into system. Once an attacker tries to open it we will be a altered and provided with attackers information.	This is a very inexpensive and quick way to to get on top of a potential area that needs addressed before other advanced monitoring and detection tools can be implemented.
Honey creds in credentials server	IT Teams	increase security of high value credentials	Installing Honey cred will bolster security of high value credentials	Additional measure to ensure that high value targets are not compromised, allowing better peace of mind.	Xibalba has shared database credentials between development and production environments. If an attacker compromises one system, they can easily move laterally using these valid credentials.	Implementing Honey creds will provide quick solution to help identify TA, increasing security while other mitigations can be implemented.

Complete the **Solutions sheet** first to pre-populate this column's dropdown!	Which audience do you need to communicate value to?	What risk or issue does solution address?	How does solution solve the problem?	Why is solution effective?	What specific examples or statistics can strengthen your argument?	Why should this stakeholder care?
4.3.2 · 4.3.5 · 4.3.8	4.4.3	4.4.3	4.4.3	4.4.3	4.4.3	4.4.3
Solution	Stakeholder	State the problem	Propose the solution	Explain the benefits	Provide evidence or examples	Summary for specific stakeholder
Honey creds in credentials server	Legal/Compliance	High value targets like data supplied in credentials server need to have bolstered security to comply with legal.	Install Honey creds to catch information about TA.	This will provide legal with attacker information.	Once a honey cred is activated it will provide attacker information to legal for formal legal reasons.	Honey creds will provide legal with important information about the attacker.to report security incidents within specific timeframes, if notification thresholds are met,could trigger PCI-DSS breach reporting requirements
M1015: Active Directory Configuration	Executives	Unauthorized user accounts used to gain access to the network	This will make sure there are not other ways to access accounts that are not needed.	We can lessen the amount of area we need to protect. It will increase productivity and security.	If you only need to log into your account from your laptop.You do not need a remote access way to log in. By removing that remote access it will secure it from any unwanted threats.	By implementing this strategy it will improve security and productivity by reducing the amount potential areas to threat.
M1015: Active Directory Configuration	IT Teams	Reduce the risk of unauthorized access and lateral movement within the network.	Reduce attack surface by allowing IT teams to log in centrally, reducing the risk of unmanaged, rogue local accounts on individual machines.	Reducing the attack surface means reducing the amount of time needed to monitor for malicious behavior.	Currently, if an attacker compromises the development environment, they automatically have production database access. With proper AD configuration Development service accounts would only access development databases	Implementation will reduce risk of exposure and reduce attack surface areas.
M1015: Active Directory Configuration	Legal/Compliance	Unauthorized access could lead to non-compliance with regulations and data protection laws.	With proper active directory configuration, it will reduce chances on non-compliance.	Reduce scope of threat of data protection laws.	With proper active directory configuration, it will ensure compliance and avoid regulatory fines.	Active directory configurations ensures compliance, reducing risk of legal issues.
M1026: Privileged Account Management	Executives	Privileged accounts are big targets that need more security around them due to the potential high costs of what could happen if misused	Implement audits and monitoring of privileged accounts to make sure only the authorized users are logging in and see what they are doing once logged in.	If privileged accounts are monitored and audited, we could find potential misuse of access quicker. This could save the company from downtime, extra expenses, and theft of intellectual property.	If a developer used their account to access source code and then either sold or manipulated that code for sabotage. We would be able to know who did it and when.	Keeping an eye on what privileged accounts are doing could potentially save the company its entire game source code. Without secure source code the company could possibly not exist.
M1026: Privileged Account Management	IT Teams	More robust authorization of privileged accounts	Limiting the scope of permissions, monitoring privileged account usage, and ensuring accountability through logging and auditing	Reducing the amount of unauthorized account access and being able to ensure accountability will reduce unnecessary problem solving later on while increasing security.	If an attacker compromises the development server (where the .git folder was exposed), proper privileged account management would prevent them from using those same credentials to access production systems. Each environment would have its own privileged accounts with different access levels.	Implementing this mitigation will help properly secure IP, while reducing the attack surface and decreasing threat exposure.
M1026: Privileged Account Management	Legal/Compliance	Unauthorized access could lead to non-compliance with regulations and data protection laws.	With proper Privileged account management, it will reduce chances on non-compliance.	Reduce scope of threat of data protection laws.	With proper Privileged account management, it will ensure compliance and avoid regulatory fines.	Active directory configurations ensures compliance, reducing risk of legal issues.
M1032: Multi-factor Authentication	Executives	Login credentials are too easily used by improper account holders.	All account holders will use two forms of identification. (MFA)	It will be harder for cyber criminals to pretend they are someone they are not.	If someone were to obtain your password information, they could use it to log in pretending to be you. With multi factor identification they would need to provide additional information that would only be available to the proper account holder.	With minimal training, multi factor authentication can be implemented across our network. Providing better security at minimum cost.

Complete the **Solutions sheet** first to pre-populate this column's dropdown!	Which audience do you need to communicate value to?	What risk or issue does solution address?	How does solution solve the problem?	Why is solution effective?	What specific examples or statistics can strengthen your argument?	Why should this stakeholder care?
4.3.2 · 4.3.5 · 4.3.8	4.4.3	4.4.3	4.4.3	4.4.3	4.4.3	4.4.3
Solution	Stakeholder	State the problem	Propose the solution	Explain the benefits	Provide evidence or examples	Summary for specific stakeholder
M1032: Multi-factor Authentication	IT Teams	Weak passwords and unauthorized access are common entry points for attackers	Implement 0auth 2.0 and MFA across all critical systems	Simple integration reduces workload with minimal training.	0auth 2.0 is widely supported, reducing integration and training time.	This solution adds a layer of security to protect our system. Without creating a wide workload, it is easy and straightforward.
M1032: Multi-factor Authentication	Legal/Compliance	Unauthorized access could lead to non-compliance with regulations and data protection laws.	Implement 0auth 2.o and MFA for all sensitive data sources.	Ensures compliance, avoids penalties, and streamlines audit readiness.	MFA ensures audit ready compliance, avoiding regulatory fines.	This solution ensures compliance with regulations like HIPAA, reducing risk of legal issues and penalties.
Web bug on internal web server containing IP	Executives	There are areas that source code may already be exposed.	Installing traps in these areas will give us a heads up if anyone is already opening these pages.	This could potentially save the company's intellectual property. Saving the money, time, and possibly the company itself.	A cyber criminal opens a page with company source code. We will immediately get an alert and provide us with information about who is doing it. Possibly allowing us to watch them and see what else they are up to.	This is yet another cheap and easy way to install some kind of safeguard until further tools can be used or problems are solved
Web bug on internal web server containing IP	IT Teams	Highly valuable IP exposed right now.	Quickly install web bug to provide alerts if data is read.	This is a quick and easy solution until more tools and mitigations can be established.	With a web bug, IT would be alerted right way with TA information to follow for any data extraction.	This will be a quick easy way to set a trap in case a TA tries to view company IP.
Web bug on internal web server containing IP	Legal/Compliance	High value targets like IP need to have bolstered security to comply with legal.	Install web bug to catch information about TA.	This will provide legal with attacker information.	Once web bug is activated it will provide attacker information to legal for formal legal reasons.	Web bug will provide legal with important information about the attacker.to report security incidents within specific timeframes, if notification thresholds are met,could trigger PCI-DSS breach reporting requirements

Complete the **Solutions sheet** first to pre-populate this column's dropdown!	Which audience do you need to communicate value to?	What risk or issue does solution address?	How does solution solve the problem?	Why is solution effective?	What specific examples or statistics can strengthen your argument?	Why should this stakeholder care?
4.3.2 · 4.3.5 · 4.3.8	4.4.3	4.4.3	4.4.3	4.4.3	4.4.3	4.4.3
Solution	Stakeholder	State the problem	Propose the solution	Explain the benefits	Provide evidence or examples	Summary for specific stakeholder

Complete the **Solutions sheet** first to pre-populate this column's dropdown!	Which audience do you need to communicate value to?	What risk or issue does solution address?	How does solution solve the problem?	Why is solution effective?	What specific examples or statistics can strengthen your argument?	Why should this stakeholder care?
4.3.2 · 4.3.5 · 4.3.8	4.4.3	4.4.3	4.4.3	4.4.3	4.4.3	4.4.3
Solution	Stakeholder	State the problem	Propose the solution	Explain the benefits	Provide evidence or examples	Summary for specific stakeholder

Complete the **Solutions sheet** first to pre-populate this column's dropdown!	Which audience do you need to communicate value to?	What risk or issue does solution address?	How does solution solve the problem?	Why is solution effective?	What specific examples or statistics can strengthen your argument?	Why should this stakeholder care?
4.3.2 · 4.3.5 · 4.3.8	4.4.3	4.4.3	4.4.3	4.4.3	4.4.3	4.4.3
Solution	Stakeholder	State the problem	Propose the solution	Explain the benefits	Provide evidence or examples	Summary for specific stakeholder

Complete the **Solutions sheet** first to pre-populate this column's dropdown!	Which audience do you need to communicate value to?	What risk or issue does solution address?	How does solution solve the problem?	Why is solution effective?	What specific examples or statistics can strengthen your argument?	Why should this stakeholder care?
4.3.2 · 4.3.5 · 4.3.8	4.4.3	4.4.3	4.4.3	4.4.3	4.4.3	4.4.3
Solution	Stakeholder	State the problem	Propose the solution	Explain the benefits	Provide evidence or examples	Summary for specific stakeholder